PHISH-001

Simulated Phishing Incident Response Investigation

Project Type: Cybersecurity Incident Response
Platform: Kali Linux
Investigation Type: Controlled Laboratory Simulation
Case ID: PHISH-001

---

1. Executive Summary

This project demonstrates a controlled phishing incident response investigation performed in an isolated cybersecurity training environment.

A simulated phishing email was created containing a suspicious URL and a benign attachment. The investigation involved email header analysis, SPF/DKIM/DMARC assessment, URL investigation, attachment analysis, file hashing, metadata examination, network traffic capture, IOC extraction, IOC enrichment, and MITRE ATT&CK mapping.

Network traffic generated within the controlled laboratory was captured using tcpdump and analyzed using tshark and Wireshark.

No real users, credentials, malicious infrastructure, or external phishing systems were involved.

---

2. Objectives

The main objectives of the investigation were:

- Demonstrate phishing email analysis.
- Examine email headers.
- Assess SPF, DKIM and DMARC information.
- Extract and investigate URLs.
- Analyze the attached file.
- Calculate a SHA-256 file hash.
- Examine file metadata.
- Capture and analyze network traffic.
- Extract and document indicators of compromise.
- Map observed activity to MITRE ATT&CK.
- Develop an incident response plan.
- Produce a structured forensic investigation report.

---

3. Lab Environment

The investigation was performed in a controlled Kali Linux environment.

The laboratory consisted of:

- Kali Linux investigation workstation.
- Local harmless HTTP training server.
- Simulated phishing email.
- Benign simulated attachment.
- tcpdump for packet capture.
- tshark for command-line PCAP analysis.
- Wireshark for graphical packet analysis.

No real phishing infrastructure was contacted.

---

4. Investigation Methodology

The investigation followed this workflow:

1. Creation of simulated phishing email.
2. Collection of email evidence.
3. Header analysis.
4. SPF/DKIM/DMARC assessment.
5. URL extraction.
6. DNS investigation.
7. Attachment identification.
8. SHA-256 hashing.
9. Metadata analysis.
10. Network traffic generation.
11. PCAP capture.
12. PCAP analysis.
13. IOC extraction.
14. IOC enrichment.
15. MITRE ATT&CK mapping.
16. Incident response planning.

---

5. Email Header Analysis

The simulated email contained the following information:

From: security-alert@training.test

To: analyst@training.test

Subject: Urgent: Password Expiration Notice

Return-Path: security-alert@training.test

Reply-To: security-alert@training.test

The email also contained a Message-ID and timestamp.

The artifact did not contain complete Received or Authentication-Results headers. Therefore, complete authentication validation could not be performed directly from the email artifact.

---

6. SPF/DKIM/DMARC Analysis

SPF

The simulated training domain did not provide a public SPF record.

Therefore, SPF authentication could not be independently validated.

DKIM

No DKIM-Signature header was present in the simulated email.

Therefore, DKIM validation could not be performed.

DMARC

No public DMARC policy was available for the simulated training domain.

Therefore, DMARC enforcement could not be independently validated.

These limitations are intentional because the investigation uses a controlled training domain.

---

7. URL Analysis

The URL extracted from the simulated email was:

`http://phishing-lab.test/update`

The domain was intentionally created as a laboratory-only domain.

DNS investigation showed that the domain was not publicly resolvable.

The URL was therefore treated as a simulation-only indicator.

---

8. Attachment Analysis

The attachment analyzed during the investigation was:

`Password_Expiration_Notice.txt`

The file was identified as a plain text file.

The SHA-256 hash was calculated using the `sha256sum` utility.

The file was also examined using:

- `file`
- `sha256sum`
- `exiftool`
- `strings`

The attachment contained only the benign training message and did not contain malicious code.

SHA-256: [INSERT YOUR HASH]

---

9. Network Traffic Analysis

A controlled HTTP server was created within the laboratory.

The server operated on TCP port 8080.

Harmless HTTP requests were generated using curl.

Traffic was captured using tcpdump and stored as:

`pcap/phish-001.pcap`

The PCAP was subsequently analyzed using tshark and Wireshark.

Observed activity included HTTP requests and responses involving the controlled laboratory service.

No external malicious infrastructure was contacted.

---

10. IOC Inventory

Type	Indicator	Source	Confidence
Email	security-alert@training.test	Email Header	High
Domain	phishing-lab.test	Email URL	High
URL	http://phishing-lab.test/update	Email Body	High

Type	Indicator	Source	Confidence
SHA-256	[INSERT HASH]	Attachment	High

All indicators are associated with the controlled training environment and should not be treated as real-world malicious indicators.

---

11. IOC Enrichment

The indicators were examined according to their type.

The sender address was identified from the email header.

The domain and URL were identified from the email body.

The attachment hash was calculated to provide a unique file identifier.

Because the investigation uses a reserved laboratory domain, external reputation services were not used to classify the domain as malicious.

---

12. MITRE ATT&CK Mapping

The investigation demonstrates the following concepts:

Tactic	Technique/Concept	Evidence
Initial Access	Phishing	Simulated email
Execution	User interaction concept	Simulated URL access
Network Forensics	Controlled HTTP activity	PCAP

The MITRE ATT&CK mapping was limited to behaviors actually demonstrated by the controlled laboratory exercise.

---

13. Incident Response

Detection

The incident was detected through analysis of a simulated phishing email.

Analysis

The email, URL, attachment and network evidence were analyzed.

Containment

Recommended actions include:

- Quarantine the phishing email.
- Search mailboxes for matching indicators.
- Block confirmed malicious URLs/domains.
- Identify users who interacted with the message.
- Reset credentials if compromise occurred.
- Review authentication logs.

Eradication

Recommended actions include:

- Remove malicious messages and files.
- Block identified indicators.
- Search for additional copies.
- Remove any persistence if discovered.

No malicious persistence was created in this simulation.

Recovery

Recommended actions include:

- Restore affected systems if required.
- Reset compromised credentials.
- Monitor affected systems.
- Review authentication and endpoint logs.

Lessons Learned

The investigation demonstrates the importance of:

- Email security controls.
- SPF/DKIM/DMARC.
- Multi-factor authentication.
- User awareness training.
- IOC monitoring.
- Centralized logging.
- Network monitoring.
- Incident response procedures.

---

14. Investigation Timeline

Time	Activity
14:02:11 UTC	Simulated phishing email timestamp
14:05 UTC	Investigation initiated
14:06 UTC	Email headers reviewed
14:08 UTC	Sender/recipient information documented
14:10 UTC	SPF/DKIM/DMARC assessed
14:12 UTC	URL extracted
14:15 UTC	Attachment identified and hashed
14:20 UTC	Network capture performed
14:25 UTC	PCAP analyzed
14:26 UTC	IOC enrichment performed
14:27 UTC	MITRE ATT&CK mapping completed
14:30 UTC	Incident response recommendations documented

---

15. Evidence Screenshots

The following evidence screenshots should be inserted into the final report:

1. Email/header analysis
2. URL and DNS analysis
3. Attachment hash
4. Attachment metadata
5. PCAP/tshark analysis
6. Wireshark analysis
7. IOC inventory

---

16. Results

The investigation successfully demonstrated a complete simulated phishing investigation workflow.

The following activities were completed:

- Email analysis
- Header investigation
- Authentication assessment
- URL extraction
- DNS investigation
- Attachment analysis

- SHA-256 hashing
- Metadata analysis
- Network traffic capture
- PCAP analysis
- IOC extraction
- IOC enrichment
- MITRE ATT&CK mapping
- Incident response planning

---

17. Recommendations

Organizations should consider:

- Enforcing strong email security controls.
- Configuring SPF, DKIM and DMARC correctly.
- Enabling multi-factor authentication.
- Conducting regular security awareness training.
- Monitoring suspicious URLs and domains.
- Centralizing endpoint and authentication logs.
- Establishing clear incident response procedures.
- Performing regular phishing simulations.

---

18. Conclusion

The PHISH-001 project demonstrated how Kali Linux can be used as a cybersecurity investigation workstation for a controlled phishing incident response exercise.

The investigation covered the complete workflow from initial email analysis through IOC extraction, network investigation, ATT&CK mapping and incident response planning.

The exercise was conducted entirely within a controlled laboratory environment. No real credentials, users or malicious external infrastructure were involved.